step: 1.1

plan: ../PLAN-MASTER.md

agent: senior-developer

status: done

completed_at: 2026-11-02 20:55

deps: []

STEP 1.1 — Auth/RBAC Guard, Đóng tự đăng ký & Vòng đời Token (`G0-1` & `G0-5`)

Input nhận

- Căn cứ `docs/architecture/ADR-001-system-architecture-roadmap.md` và `docs/architecture/ARCH-AUDIT-system-2026-11-02.md`
- Quyết định: Đóng tự đăng ký công khai (`/api/auth/register`), chỉ Admin được tạo user; Cookie session tương thích cả HTTP LAN (`COOKIE_SECURE=false`) và HTTPS Internet.

Nhiệm vụ

1. Thêm trường `tokenVersion Int @default(1)` vào model `User` trong `prisma/schema.prisma`. Chạy `npx prisma db push` và `npx prisma generate` (lưu ý GOTCHAS G010).
2. Chuyển đổi `hashPassword` và `verifyPassword` trong `src/lib/auth.ts` từ `scryptSync` sang `crypto.scrypt` async non-blocking. Đưa `tokenVersion` vào payload JWT và kiểm tra `tokenVersion` khi verify session/token.
3. Tạo `src/lib/api-guard.ts` cung cấp higher-order wrapper `withApiAuth(handler, { requiredRole, requiredPermission })` kiểm tra session, kiểm tra `tokenVersion` khớp với DB, và kiểm tra cờ `mustChangePassword` (chặn `403 PASSWORD_CHANGE_REQUIRED` nếu truy cập các API khác ngoài `change-password` và `logout`).
4. Khởi tạo `src/proxy.ts` (chuẩn Next.js 16 theo docs `node_modules/next/dist/docs/01-app/03-api-reference/03-file-conventions/proxy.md`) bảo vệ các route `/admin/**`, `/api/users/**`, `/api/system/**`.
5. Bảo vệ chặt chẽ các API quản trị người dùng:

- `src/app/api/users/route.ts`: Chỉ `ADMIN` được tạo user (`POST`) và xem toàn bộ danh sách phân quyền.
- `src/app/api/users/[userId]/route.ts`: Chỉ `ADMIN` được `PATCH`/`DELETE` hoặc chỉnh sửa role của user.
- `src/app/api/auth/register/route.ts`: Khóa đăng ký công khai (trả `403 Registration is closed`).

- Ẩn/khóa đường dẫn tự đăng ký trên UI `src/app/login/page.tsx` và thông báo tài khoản do Admin cấp tại `src/app/register/page.tsx`.

6. Bảo vệ quyền truy cập tài nguyên:

- `src/app/api/attachments/[id]/route.ts`: Bắt buộc auth và kiểm tra quyền sở hữu/quyền project trước khi xóa (`DELETE`).
- `src/app/api/tickets/[ticketId]/route.ts`: Ẩn `internalNotes` và comment nội bộ đối với user ẩn danh / khách hàng.
- `src/app/api/tickets/[ticketId]/comments/route.ts`: Chặn khách hàng/user ẩn danh giả mạo `isStaff: true`.
- `src/app/api/notifications/email-logs/route.ts`: Chỉ `ADMIN` mới được xem/xóa log email hệ thống.

7. Đổi mật khẩu thành công (`src/app/api/auth/change-password/route.ts`) -> tăng `tokenVersion` để thu hồi toàn bộ token/session cũ.

Definition of Done

- [x] Model `User` có `tokenVersion` trong DB PostgreSQL và `prisma generate` thành công.
- [x] `scrypt` async hoạt động mượt mà, không block Event Loop khi login.
- [x] User ẩn danh gọi `POST /api/users`, `PATCH /api/users/[id]`, `DELETE /api/users/[id]`, `DELETE /api/attachments/[id]`, `/api/notifications/email-logs` đều nhận `401` hoặc `403`.
- [x] `/api/auth/register` từ chối đăng ký công khai; UI `/login` và `/register` đã ẩn/khóa form tự đăng ký tự do.
- [x] `/api/tickets/[ticketId]` ẩn danh không xem được `internalNotes`; không thể inject `isStaff: true`.
- [x] Đổi mật khẩu vô hiệu hóa ngay lập tức token cũ.

Đã làm

1. **Prisma Model & Migration:** Đã bổ sung `tokenVersion Int @default(1)` và `isActive Boolean @default(true)` vào model `User` trong `prisma/schema.prisma`. Chạy `npx prisma db push` và `npx prisma generate` thành công cập nhật PostgreSQL và Prisma Client.
2. **Nâng cấp `src/lib/auth.ts`:**

- Chuyển `hashPassword` và `verifyPassword` sang `crypto.scrypt` Promise-based (async) hoàn toàn không block Event Loop.
- Bổ sung `tokenVersion` và `role` vào payload JWT khi tạo session (`createSession`, `createJwtToken`).
- Cập nhật `getSessionUser`: đối chiếu `tokenVersion` của token với database, nếu không khớp (do đổi mật khẩu hoặc đăng xuất) lập tức từ chối phiên (`null`), đồng thời kiểm tra `isActive === true`.

3. **Dựng Higher-order Guard `src/lib/api-guard.ts`:**

- Cung cấp wrapper `withApiAuth(handler, { requiredRole, requiredPermission, allowMustChangePassword })`.
- Tự động kiểm tra authentication (`getSessionUser`), kiểm tra tài khoản `isActive`.

- Cưỡng chế cờ `mustChangePassword === true`: chặn `403 { code: "PASSWORD_CHANGE_REQUIRED" }` ở mọi API trừ luồng đổi mật khẩu (`allowMustChangePassword: true`).
- Tích hợp kiểm tra quyền RBAC qua `hasPermission` và danh sách roles hợp lệ.

4. **Khởi tạo `src/proxy.ts` (Next.js 16):**

- Đặt tại `src/proxy.ts` tuân thủ file convention mới của Next.js 16 (`proxy.md`).
- Chặn các route quản trị hệ thống: `/admin/:path*`, `/api/admin/:path*`, `/api/users/:path*`, `/api/users`, `/api/notifications/email-logs/:path*`, `/api/notifications/email-logs`.
- Chặn `401` nếu thiếu token và `403` nếu không có vai trò `ADMIN`.

5. **Bảo vệ API Users & Auth:**

- `src/app/api/users/route.ts`: Khóa quyền `ADMIN` cho `GET` (xem danh sách phân quyền) và `POST` (tạo người dùng).
- `src/app/api/users/[userId]/route.ts`: Khóa quyền `ADMIN` cho `PATCH` và `DELETE`. Khi đổi mật khẩu user, tự động tăng `tokenVersion: { increment: 1 }` để hủy session cũ của user đó.
- `src/app/api/users/[userId]/send-credentials/route.ts`: Cập nhật `await hashPassword` và tăng `tokenVersion`.
- `src/app/api/auth/register/route.ts`: Đóng đăng ký tự do, trả về `403 { error: "Registration is closed" }`.
- UI `src/app/login/page.tsx`: Gỡ bỏ liên kết tự đăng ký, bổ sung thông báo tài khoản nội bộ do Quản trị viên cấp phát.
- UI `src/app/register/page.tsx`: Khóa form đăng ký tự do, hiển thị thẻ thông báo chính sách an ninh mạng KZTEK và nút quay lại trang đăng nhập.

6. **Bảo vệ Tài nguyên & Dữ liệu nhạy cảm:**

- `src/app/api/attachments/[id]/route.ts`: Bắt buộc auth trước khi xóa (`DELETE`), kiểm tra quyền sở hữu (`uploaderId`) hoặc quyền quản lý dự án (`OWNER`/`MANAGER` trong `ProjectMember`) hoặc vai trò `ADMIN`.
- `src/app/api/tickets/[ticketId]/route.ts`: Ẩn `internalNotes` và loại bỏ các bình luận `isInternalOnly` đối với khách hàng / user ẩn danh.
- `src/app/api/tickets/[ticketId]/comments/route.ts`: Chặn khách hàng / user ẩn danh tự gắn cờ `isStaff: true` hoặc `isInternalOnly: true`.
- `src/app/api/notifications/email-logs/route.ts`: Chỉ `ADMIN` được truy cập `GET`, `POST`, `DELETE`.

7. **Thu hồi Token khi Đổi Mật khẩu:**

- `src/app/api/auth/change-password/route.ts`: Khi đổi mật khẩu thành công, tăng `tokenVersion: { increment: 1 }`, đặt `mustChangePassword: false`, và cấp session token mới đồng bộ. Toàn bộ JWT cũ lập tức vô hiệu hóa.

8. **Kiểm thử tự động & Xác minh:**

- Xây dựng kịch bản kiểm thử độc lập `scripts/test_step_1_1.ts`: Kiểm tra 7/7 tiêu chí bảo mật đều đạt kết quả PASS 100%.
- Typecheck qua `npx tsc --noEmit` đạt 0 lỗi.

Artifact

- `prisma/schema.prisma`
- `src/lib/auth.ts`
- `src/lib/api-guard.ts`
- `src/proxy.ts`
- `src/app/api/auth/login/route.ts`
- `src/app/api/auth/register/route.ts`
- `src/app/api/auth/change-password/route.ts`
- `src/app/api/users/route.ts`
- `src/app/api/users/[userId]/route.ts`
- `src/app/api/users/[userId]/send-credentials/route.ts`
- `src/app/api/attachments/[id]/route.ts`
- `src/app/api/tickets/[ticketId]/route.ts`
- `src/app/api/tickets/[ticketId]/comments/route.ts`
- `src/app/api/notifications/email-logs/route.ts`
- `src/app/login/page.tsx`
- `src/app/register/page.tsx`
- `scripts/test_step_1_1.ts`

Quyết định quan trọng

- Tuân thủ file convention Next.js 16: đặt file tại `src/proxy.ts` thay vì `middleware.ts` theo `AGENTS.md`.
- Áp dụng kiến trúc Defense-in-Depth 2 lớp:
  - Lớp 1: Gateway `src/proxy.ts` kiểm tra chữ ký JWT và role tại tầng Edge/Proxy.
  - Lớp 2: Higher-order Guard `src/lib/api-guard.ts` (`withApiAuth`) đối chiếu database thực tế về `tokenVersion`, `isActive`, `mustChangePassword` và RBAC quyền hạn.

Handoff Payload — bước sau đọc phần này (chỉ phần này, không cần đọc "Đã làm")

- **do_not_redo:**
  - Không cần tạo lại `withApiAuth`, `proxy.ts`, hoặc sửa đổi cơ chế `tokenVersion` / `scrypt` async.
  - Không mở lại form tự đăng ký `/api/auth/register` hay UI `/register`.
- **watch_out:**
  - Trong Bước 1.2: Khi cấu hình Cookie `httpOnly: true`, hãy giữ logic `secure: process.env.COOKIE_SECURE === "true"` để client mạng LAN HTTP (`COOKIE_SECURE=false`) không bị mất cookie phiên sau khi đăng nhập.
  - Lưu ý các component client dùng `document.cookie` để lấy token sẽ không đọc được token nữa khi có `httpOnly: true`; hệ thống cần sử dụng Cookie tự động đính kèm qua `credentials: "same-origin"` hoặc `same-site` chuẩn.
- **next_inputs:**

- Chuyển giao sang Bước 1.2: Tích hợp `isomorphic-dompurify` làm Seam chống Stored XSS trong `RichMarkdown` & `WysiwygEditor`, escape HTML email trong `mail.ts`, mã hóa AES-256-GCM các secret trong `SystemSetting`.

Commit

- Hash:
- Đã push:

Status icons: ⬜ Todo | 🔄 In Progress | ✅ Done | 🛑 Blocked | ⏭️ Skipped